



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de Aprendizaje	3
Topología del experimento	3
Software requerido	3
Herramientas	3
Marco Teórico	4
FIPS PUB 200	4
Desarrollo	5
Reconocimiento	5
Simulación de Ataque	6
Implementación de Controles	6
Monitoreo de Tráfico	7
Autenticación y Seguridad	8
Ejemplos	8
Política de Contraseñas	8
Política de Complejidad de Contraseñas	9
Conclusiones	9

List of Figures

1	Topología de Experimentación	4
2	Identificación de Servicios Activos	5
3	Escaneo de Puertos y Servicios Vulnerables	6
4	Activación de Firewall	6
5	Revisión de Conexiones Activas	7
6	Wireshark en Kali	7
7	Políticas de Seguridad y Autenticación	8
8	Configuración de Archivo de Credenciales	8

9	Comprobación de Nueva Configuración de Contraseñas	9
10	Configuración de Archivo para Contraseñas Seguras	9

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender e implementar controles básicos de seguridad basados en NIST
- Analizar vulnerabilidades en sistemas expuestos
- Aplicar mecanismos de monitoreo, autenticación y control de acceso
- Evaluar eventos de seguridad mediante análisis de logs
- Relacionar la práctica con dominios de seguridad como auditoría, autenticación y protección de sistemas

Topología del experimento

La Figura 1 representa un laboratorio de pruebas de penetración (pentesting), en el cual el atacante utiliza Kali Linux para ejecutar técnicas de reconocimiento y explotación sobre Metasploitable 2, una máquina virtual diseñada con vulnerabilidades intencionales.

De manera complementaria, la VM con Ubuntu Desktop cumple el rol de sistema de monitoreo y análisis, desde donde se emplean herramientas de inspección de tráfico y revisión de registros para identificar indicios de intrusión y evaluar la efectividad de los controles de seguridad implementados.

Para lograr una visibilidad adecuada del tráfico, este sistema debe configurarse en un entorno de red que permita la captura de paquetes o el acceso a los logs generados por los sistemas analizados.

Software requerido

- VirtualBox / VMware
- Kali Linux
- Metasploitable 2
- Ubuntu Desktop

Herramientas

- Nmap
- Wireshark
- Netstat
- UFW (firewall)

El estudiante deberá presentar en su informe de laboratorio:

- Evidencia del escaneo realizado (capturas de Nmap)
- Identificación de vulnerabilidades detectadas
- Configuración aplicada en el firewall
- Capturas del análisis de tráfico con Wireshark
- Análisis de logs generados durante la práctica



Figure 1: Topología de Experimentación

Marco Teórico

El estándar **NIST SP 800-171** define un conjunto de controles mínimos para proteger información sensible en sistemas no federales. Estos controles se agrupan en dominios como:

- Control de acceso
- Auditoría
- Autenticación
- Integridad de la información

En entornos de laboratorio, estos principios pueden aplicarse mediante la simulación de ataques y la implementación de mecanismos de defensa en sistemas vulnerables.

FIPS PUB 200

FIPS significa *Federal Information Processing Standards*. Es un conjunto de normas de seguridad publicadas por el gobierno de Estados Unidos a través del NIST.

Define cómo deben protegerse y procesarse los datos sensibles en sistemas informáticos.

En la práctica, **FIPS** establece reglas sobre:

- Cifrado de datos
- Autenticación segura
- Integridad de la información
- Requisitos de seguridad en hardware y software

Desarrollo

Reconocimiento

```
(msosa-kali@msosa-kali)-[~]
$ nmap -sV 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:31 -0500
Nmap scan report for 192.168.100.210
Host is up (0.00045s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; O
Ss: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://
/nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.14 seconds
```

Figure 2: Identificación de Servicios Activos

En la figura se pueden apreciar los servicios activos en Metasploitable. En listado, se pueden encontrar todos los puertos que mantiene abiertos.

Simulación de Ataque

```
└─$ nmap -A 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:35 -0500
Nmap scan report for 192.168.100.210
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.100.184
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRF
Y, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName
=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-28T15:36:50+00:00; 0s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
```

Figure 3: Escaneo de Puertos y Servicios Vulnerables

Con el comando `nmap -A 192.168.100.210` se puede comprobar toda la información de todos los puertos abiertos que mantiene Metasploitable. Esto permite conocer qué servicios vulnerables tiene y cuáles podemos atacar.

Implementación de Controles

```
(msosa-kali@msosa-kali)-[~]
└─$ sudo ufw enable
[sudo] contraseña para msosa-kali:
Firewall is active and enabled on system startup

(msosa-kali@msosa-kali)-[~]
└─$ sudo ufw deny from 192.168.122.226
Rule added
```

Figure 4: Activación de Firewall

En la figura 4 se puede apreciar que se hizo un bloqueo a la dirección IP de Metasploitable para que esta no pueda acceder a los mismos servicios a los que quiere acceder.

```
msosa-kali@msosa-kali:~$ netstat -tulnp
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
PID/Program name
```

Figure 5: Revisión de Conexiones Activas

Además, en la figura 5 se puede apreciar cuáles son las conexiones activas que mantiene el dispositivo.

Monitoreo de Tráfico

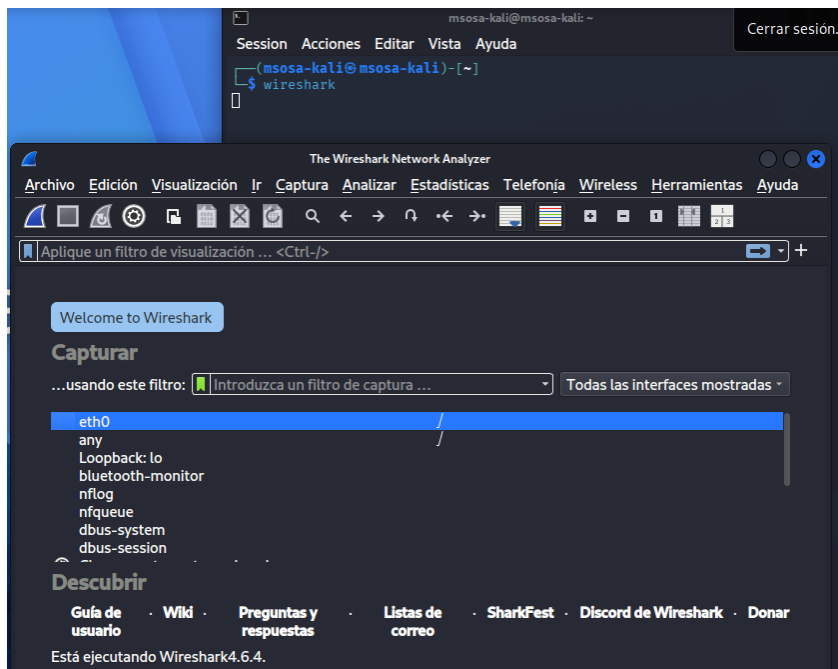


Figure 6: Wireshark en Kali

La aplicación de Wireshark permite conocer el tráfico que transita por el dispositivo, permitiendo entender cuáles y a dónde salen nuestros paquetes, además de conocer aquellos que se nos son enviados.

Autenticación y Seguridad

```
(msosa-kali@msosa-kali)-[~]
$ sudo passwd
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente

(msosa-kali@msosa-kali)-[~]
$ cat /etc/login.defs
#
# /etc/login.defs - Configuration control definitions for the shadow packag
#
#
# REQUIRED for useradd/userdel/usermod
#   Directory where mailboxes reside, _or_ name of file, relative to the
#   home directory.  If you _do_ define MAIL_DIR and MAIL_FILE,
#   MAIL_DIR takes precedence.
#
#   Essentially:
#   - MAIL_DIR defines the location of users mail spool files
#     (for mbox use) by appending the username to MAIL_DIR as defined
#     below.
#   - MAIL_FILE defines the location of the users mail spool files as th
#     e
#     fully-qualified filename obtained by prepending the user home
#     directory before $MAIL_FILE
#
# NOTE: This is no more used for setting up users MAIL environment variable
#       which is, starting from shadow 4.0.12-1 in Debian, entirely the
#       job of the pam_mail PAM modules
#       See default PAM configuration files provided for
#       login, su, etc.
#
# This is a temporary situation: setting these variables will soon
# move to /etc/default/useradd and the variables will then be
# no more supported
MAIL_DIR      /var/mail
MAIL_FILE     .mail
```

Figure 7: Políticas de Seguridad y Autenticación

Es posible además configurar aquellas políticas de seguridad y autenticación de usuarios dentro del dispositivo para que no sean vulnerables y la información sea accesible de forma controlada.

Ejemplos

Política de Contraseñas

```
msosa-kali@msosa-kali: ~
Session Acciones Editar Vista Ayuda
GNU nano 8.7.1 /etc/login.defs *
#
PASS_MAX_DAYS 30
PASS_MIN_DAYS 2
PASS_WARN_AGE 7
```

Figure 8: Configuración de Archivo de Credenciales

En la figura 8 se puede apreciar la modificación del archivo `/etc/login.defs` para cambiar cada cuánto se debe actualizar las contraseñas, además de otras configuraciones importantes.

En la figura 9 se observa la ejecución y nueva información de la contraseña que se generó para un nuevo usuario.

```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
(msosa-kali@msosa-kali)-[~]  
$ sudo nano /etc/login.defs  
(msosa-kali@msosa-kali)-[~]  
$ sudo adduser estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente  
Cambiando la información de usuario para estudiante1  
Introduzca el nuevo valor, o pulse INTRO para usar el valor predeterminado  
Nombre completo []: Estudiante  
Número de habitación []: 0  
Teléfono del trabajo []: 0  
Teléfono de casa []: 0  
Otro []:  
Is the information correct? [Y/n] Y  
(msosa-kali@msosa-kali)-[~]  
$ sudo passwd estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente  
(msosa-kali@msosa-kali)-[~]  
$ sudo chage -l estudiante1  
Último cambio de contraseña : abr 30, 2026  
026  
La contraseña caduca : may 30, 2026  
Contraseña inactiva : nunca  
La cuenta caduca : nunca  
Número de días mínimo entre cambio de contraseña : 2  
Número de días máximo entre cambio de contraseña : 30  
Número de días de aviso antes de que caduque la contraseña : 7  
(msosa-kali@msosa-kali)-[~]
```

Figure 9: Comprobación de Nueva Configuración de Contraseñas

Política de Complejidad de Contraseñas

```
(msosa-kali@msosa-kali)-[~]  
$ sudo nano /etc/pam.d/common-password  
(msosa-kali@msosa-kali)-[~]  
$ sudo passwd estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente
```

Figure 10: Configuración de Archivo para Contraseñas Seguras

Al editar el archivo `/etc/pam.d/common-password` se puede exigir una contraseña con mayúsculas, números y longitud mínima, además de símbolos y ciertos requisitos para una contraseña mucho más segura.

Conclusiones

- La seguridad requiere múltiples controles coordinados

- Kali Linux evidencia vulnerabilidades fácilmente explotables
- Ubuntu demuestra la importancia del monitoreo y control
- NIST proporciona una base sólida de seguridad
- El monitoreo continuo es clave para detectar amenazas
- La seguridad es un proceso dinámico que requiere mejora constante